Cheatsheet AZ-104 — 02 · RBAC: roles integrados, ámbitos, herencia e interpretación de asignaciones

1. Las tres piezas de una asignación

Pieza	Qué es	Detalles de examen
Security principal	Usuario, **grupo** (anidación transitiva), service principal o managed identity	Mejor asignar a grupos. Los guests también reciben roles. Un principal puede tener varias asignaciones a la vez
Role definition	Colección de permisos en JSON: `Actions`, `NotActions`, `DataActions`, `NotDataActions`, `AssignableScopes`	`NotActions` **resta** permisos dentro del mismo rol; **no es una denegación**: otro rol puede volver a conceder la acción
Scope	Management group → suscripción → resource group → recurso	Se **hereda** hacia abajo. Lo efectivo es la **unión** de todas las asignaciones (la más permisiva gana). Solo los **deny assignments** (deployment stacks / managed apps; no se crean a mano) restan

- Límites: **5 000** asignaciones por suscripción, **500** por management group, **5 000** roles personalizados por tenant.
- Una asignación nueva puede tardar **unos minutos** en aplicarse (hasta 10, más si el token está en caché). Cada cambio queda en el **Activity log** (Microsoft.Authorization/roleAssignments/write).
- RBAC gobierna el **plano de control** (`management.azure.com`). El plano de datos (blobs, colas, Key Vault en modo RBAC) exige roles con **DataActions**, o bien claves / SAS.
- Opcionales: **condición ABAC** (roles de datos de blob y cola, y para delegar asignaciones de rol con el RBAC Administrator), descripción, y asignaciones **elegibles** con PIM para recursos de Azure (P2).

2. Roles integrados que hay que distinguir

Rol	Puede	No puede	Señal
Owner	Todo, incluido **asignar roles** y gestionar **locks**	—	"full access including access management"
Contributor	Crear y gestionar cualquier recurso	Asignar roles, crear o borrar locks, elevar acceso (NotActions `Microsoft.Authorization/*/Write`)	"manage everything except access"
Reader	Ver recursos	Cambiar nada; tampoco **listar claves** de storage (es un POST)	"view only"
User Access Administrator	Gestionar acceso (asignaciones) y locks	Gestionar recursos	"manage user access to resources"
Role Based Access Control Administrator	Solo asignar roles (ideal para delegar con condiciones)	Nada más; ni locks ni recursos	"assign roles, nothing else, least privilege"
Virtual Machine Contributor	Crear, arrancar, parar, redimensionar y borrar VMs y discos; crear NICs y unirlas a subredes	Crear VNets o NSGs, gestionar la cuenta de storage, asignar acceso, entrar en la VM	"manage VMs but not the network they connect to"
Network Contributor	Toda la red (VNet, NSG, LB, PIP)	Nada fuera de Microsoft.Network	"manage networking only"
Storage Account Contributor	Gestionar cuentas y **listar claves**	Leer datos con identidad Entra	"manage storage accounts"
Storage Blob Data Owner / Contributor / Reader	Datos de blobs vía Entra (plano de datos)	Gestionar la cuenta	"access blobs with Entra ID"
Storage Account Key Operator Service Role	Listar y **regenerar** claves	Nada más	"rotate keys, least privilege"
Security Admin / Security Reader	Defender for Cloud, políticas de seguridad	Gestionar recursos	"security recommendations"
Monitoring Contributor / Reader · **Log Analytics Contributor / Reader**	Alertas, diagnostic settings, workspaces y consultas	Resto de recursos	"configure alerts", "query logs"
Backup Contributor / Operator / Reader	Gestionar backups en el vault (Operator: no borrar)	Crear el vault (Contributor sí)	"manage backups"
Website Contributor · **Web Plan Contributor**	Web apps · App Service plans	Lo otro	"manage the web app only"
Key Vault Administrator · **Key Vault Secrets User**	Todo el plano de datos de Key Vault (modo RBAC) · leer secretos	Gestionar el vault (control plane)	"read secrets, least privilege" → Secrets User
Managed Identity Operator / Contributor	Asignar una user-assigned MI a recursos · crearla	—	"assign the identity to the VM"
Resource Policy Contributor	Crear y asignar Azure Policy	Asignar roles	"manage policies"
Management Group Contributor / Reader	Gestionar o leer management groups	Recursos	"create management groups"
Cost Management Reader / Contributor · **Billing Reader**	Ver costes y presupuestos · crear presupuestos · facturas	Recursos	"auditors review costs"
Tag Contributor	Etiquetar cualquier recurso (vía PowerShell / API)	Modificar el recurso	"add tags without modifying resources"
Virtual Machine Administrator Login / User Login	Iniciar sesión en la VM con Entra ID (admin / usuario)	Gestionar la VM (eso es VM Contributor)	"sign in to the VM with Entra credentials"

Administradores clásicos (Service Administrator, Co-Administrator) están **retirados** desde agosto de 2024: si aparecen en una pregunta, la respuesta correcta siempre es un rol RBAC.

3. Interpretar asignaciones

Asignaciones	Resultado	Por qué
Reader en la suscripción + Contributor en RG1	Contributor en RG1, Reader en el resto	Unión; el ámbito más concreto no "rebaja", suma
Owner en el management group (por grupo) + Reader explícito en la suscripción	**Owner** en toda la suscripción	No existe el concepto de "asignación más restrictiva"; solo deny assignments restan
Contributor en la suscripción	Crea todo, pero **no** asigna roles ni crea locks	NotActions de Microsoft.Authorization
Reader en una cuenta de storage	Ve la cuenta; no ve claves ni blobs	listKeys es una acción; los blobs son plano de datos
Owner en la suscripción, portal con "Switch to Entra ID user account"	No lee blobs; sí con "Access key"	Owner no tiene DataActions
Virtual Machine Contributor en RG1	Arranca, para, borra y redimensiona VMs; no crea VNet ni NSG	Microsoft.Network solo parcial (NIC, join a subred, LB)
Rol personalizado con AssignableScopes = RG1	Solo asignable en RG1 o sus recursos	Fuera del ámbito no aparece en la lista
Recurso movido a otro RG o suscripción	Las asignaciones **en el recurso** se pierden (huérfanas)	Hay que recrearlas tras el move
Deny assignment de un deployment stack	Bloquea aunque seas Owner	Única forma de restar
Usuario con rol asignado pero "Authorization failed"	Esperar propagación, revisar ámbito/NotActions/DataActions, PIM sin activar, deny assignment	Lista de comprobación del examen

- **Comprobar acceso:** Access control (IAM) → **Check access** (qué tiene un usuario / grupo / MI en ese ámbito, incluidas herencias) y **View my access**. En CLI: `az role assignment list --assignee ana@contoso.com --all --include-inherited`; en PowerShell: `Get-AzRoleAssignment -SignInName ana@contoso.com -ExpandPrincipalGroups`.
- **Quién puede asignar roles:** Owner, User Access Administrator, Role Based Access Control Administrator; y un Global Administrator **solo después de elevarse** (sección 5).

4. Roles personalizados

```
{
  "Name": "VM Operator",
  "IsCustom": true,
  "Description": "Arrancar, parar y reiniciar VMs sin poder borrarlas",
  "Actions": [
    "Microsoft.Compute/virtualMachines/read",
    "Microsoft.Compute/virtualMachines/start/action",
    "Microsoft.Compute/virtualMachines/restart/action",
    "Microsoft.Compute/virtualMachines/deallocate/action",
    "Microsoft.Resources/subscriptions/resourceGroups/read"
  ],
  "NotActions": [],
  "DataActions": [],
  "NotDataActions": [],
  "AssignableScopes": [ "/subscriptions/<sub-id>", "/subscriptions/<sub-id>/resourceGroups/RG1" ]
}
```

- Se crean en el portal (IAM → Add → **Add custom role**: desde cero, **clonando** un rol o pegando JSON), con `New-AzRoleDefinition -InputFile role.json` o `az role definition create --role-definition role.json`. Actualizar: `Set-AzRoleDefinition` / `az role definition update`. No se puede borrar mientras tenga asignaciones.
- **AssignableScopes:** suscripciones, resource groups o **un solo** management group; nunca la raíz `/`. Un rol con `DataActions` no se puede asignar en un management group. Comodines (`Microsoft.Compute/*/read`) válidos.
- Para descubrir operaciones: `Get-AzProviderOperation "Microsoft.Compute/virtualMachines/*"` o `az provider operation show --namespace Microsoft.Compute`. Para partir de un rol integrado: `Get-AzRoleDefinition "Virtual Machine Contributor"` y exportar a JSON.
- Caso típico: "el equipo debe poder reiniciar VMs pero no borrarlas ni crearlas" → rol personalizado (ningún integrado encaja). "Mínimo esfuerzo" + un integrado que encaje → integrado.

5. Roles de Entra ID, roles de Azure y elevación

	Roles de Microsoft Entra ID	Roles de Azure (RBAC)
Ámbito	Tenant: usuarios, grupos, apps, licencias	Recursos: management group, suscripción, RG, recurso
Ejemplos	Global Administrator, User Administrator, Groups Administrator	Owner, Contributor, Reader, UAA
Dónde	Entra ID → Roles and administrators	Access control (IAM) en cada ámbito
Relación	**Un Global Administrator no es Owner** de nada en Azure	Un Owner de suscripción no gestiona usuarios en Entra

- **Elevate access:** Entra ID → Properties → "Access management for Azure resources" = **Yes** (solo un Global Administrator puede). Obtiene **User Access Administrator en el ámbito raíz** `/`, con el que puede asignarse Owner en el Tenant Root Group, ver todas las

suscripciones o recuperar una suscripción huérfana. Buenas prácticas: **quitar la elevación después** (toggle a No y borrar la asignación en `/`). Queda en el Activity log como `Microsoft.Authorization/elevateAccess/action`.

- Los roles de Entra y de Azure se pueden combinar en la misma persona, pero se asignan en sitios distintos y ninguno implica al otro.

6. Comandos que caen

Tarea	PowerShell (Az)	Azure CLI
Asignar rol	`New-AzRoleAssignment -SignInName ana@contoso.com -RoleDefinitionName Contributor -ResourceGroupName RG1` · a un grupo: `-ObjectId <id> -Scope /subscriptions/<id>`	`az role assignment create --assignee ana@contoso.com --role Contributor --resource-group RG1` · `--scope /subscriptions/<id>`
Listar	`Get-AzRoleAssignment -ResourceGroupName RG1` · `-SignInName ana@contoso.com -ExpandPrincipalGroups`	`az role assignment list --resource-group RG1 --include-inherited` · `--assignee ana@contoso.com --all`
Quitar	`Remove-AzRoleAssignment -SignInName ... -RoleDefinitionName ... -ResourceGroupName RG1`	`az role assignment delete --assignee ... --role ... --resource-group RG1`
Ver un rol	`Get-AzRoleDefinition "Virtual Machine Contributor"` · `(Get-AzRoleDefinition Contributor).NotActions`	`az role definition list --name "Virtual Machine Contributor"`
Rol personalizado	`New-AzRoleDefinition -InputFile role.json` · `Set-AzRoleDefinition -InputFile role.json`	`az role definition create --role-definition role.json` · `az role definition update ...`
Operaciones de un proveedor	`Get-AzProviderOperation "Microsoft.Storage/*"`	`az provider operation show --namespace Microsoft.Storage`
Elevar acceso (GA)	Portal: Entra ID → Properties → toggle	`az rest --method post --url "/providers/Microsoft.Authorization/elevateAccess?api-version=2016-07-01"`
Quitar la elevación	`Remove-AzRoleAssignment -SignInName ga@contoso.com -RoleDefinitionName "User Access Administrator" -Scope "/"`	`az role assignment delete --assignee ga@contoso.com --role "User Access Administrator" --scope "/"`

7. Árbol de decisión

```
¿Qué pide el enunciado?
├─ Gestionar todo menos el acceso ..... Contributor
├─ Gestionar acceso sin tocar recursos ..... User Access Administrator
├─ Solo asignar roles, mínimo privilegio ..... Role Based Access Control Administrator
├─ Gestionar VMs sin tocar la red ..... Virtual Machine Contributor
├─ Leer blobs con identidad Entra ..... Storage Blob Data Reader
├─ Rotar claves de storage y nada más ..... Storage Account Key Operator Service Role
├─ Ver costes sin ver recursos ..... Cost Management Reader (o Billing Reader)
├─ Reiniciar VMs pero no borrarlas (ningún integrado encaja) ..... Rol personalizado
├─ Mismo rol en muchas suscripciones ..... Asignar en el management group
├─ Global Admin que no ve las suscripciones ..... Elevate access → UAA en "/"
├─ Usuario con rol y aun así "Authorization failed" ..... Propagación / ámbito / DataActions / deny assignment
└─ Saber qué permisos tiene alguien en un recurso ..... IAM → Check access
```

8. Señales → respuesta

Enunciado	Respuesta
"least privilege", "manage VMs, cannot modify the virtual network"	Virtual Machine Contributor
"create and manage all resources, cannot grant access"	Contributor
"grant access to others, must not manage resources"	User Access Administrator
"delegate role assignments only"	Role Based Access Control Administrator
"read blob data using Microsoft Entra ID"	Storage Blob Data Reader
"Owner cannot see blobs in the portal"	Cambiar a autenticación con clave, o añadir Storage Blob Data Reader
"Reader cannot view the storage account keys"	Correcto: listKeys requiere Contributor o Storage Account Key Operator
"same permissions on 20 subscriptions, minimal effort"	Una asignación en el management group
"user has Reader on subscription and Contributor on RG"	Contributor en el RG, Reader fuera
"role assignment missing after moving the resource"	Las asignaciones a nivel de recurso no se mueven: recrearlas
"custom role cannot be assigned at management group"	Contiene DataActions, o el MG no está en AssignableScopes
"cannot delete the custom role"	Quitar primero sus asignaciones
"Global Administrator must manage all subscriptions"	Elevate access (toggle) → User Access Administrator en raíz
"Co-Administrator", "Service Administrator"	Roles clásicos retirados: usar Owner / Contributor
"which role assignments does the user have"	IAM → Check access / `az role assignment list --assignee --all`
"sign in to Windows VM with Entra credentials as admin"	Virtual Machine Administrator Login (+ extensión AADLoginForWindows)
"temporary / just-in-time Owner on a subscription"	PIM para recursos de Azure (asignación elegible, P2)

9. Errores a evitar

1. Creer que una asignación más restrictiva en un ámbito inferior "rebaja" permisos: los permisos **se suman**; solo los deny assignments restan.

2. Confundir Global Administrator con Owner: sin elevate access, un GA no ve suscripciones.
3. Dar Owner cuando basta Contributor, o Contributor cuando basta un rol de servicio (VM Contributor, Network Contributor).
4. Esperar que Reader u Owner lean blobs con Entra ID: eso son DataActions (Storage Blob Data *).
5. Poner la raíz / o varios management groups en AssignableScopes de un rol personalizado.
6. Olvidar que al mover un recurso se pierden sus asignaciones de rol a nivel de recurso.
7. Elegir Co-Administrator o Service Administrator: ya no existen.
8. Intentar borrar un rol personalizado con asignaciones activas, o asignar un rol con DataActions en un management group.
9. Dejar la elevación de acceso activa después de usarla.